

RAPPORT D'ANALYSE SECURITE MOBILE

Analyse Statique Android — MobSF

Application analysee : YouTube (com.google.android.youtube)

Version : 21.14.484 | SDK cible : 36 | Taille : 54.23 MB

Date d'analyse : 26 avril 2026 | Score de securite : 52/100 (RISQUE MOYEN)

Outil utilise : MobSF v4.0.6

Redige par : Hidaya Benchelha

Document confidentiel — usage interne

1. Resume executif

L'analyse statique de l'application YouTube (version 21.14.484) realisee via MobSF v4.0.6 revele un niveau de risque MOYEN, avec un score de securite de 52/100. Si l'application est signee par Google LLC et dispose de mecanismes de protection avances (SSL pinning, detection root, anti-tapjacking), plusieurs vulnerabilites significatives ont ete identifiees.

Les principales categories de risques concernent :

- Des composants Android exportes non proteges (24 activites, 8 receivers), exposant l'application a des interactions non autorisees depuis d'autres applications.
- L'utilisation d'algorithmes cryptographiques obsoletes (MD5, SHA-1, CBC/PKCS7) vulnérables aux attaques de collision et aux padding oracle attacks.
- La presence de cles API et de secrets potentiels en clair dans le code obfusque.
- Des permissions Android dangereuses nombreuses (15/24 identifiees comme abusees par des malwares connus), dont certaines semblent excessives au regard des fonctionnalites exposees.

Note : ces resultats doivent etre contextualises. YouTube etant une application Google de grande envergure, certaines alertes constituent des faux positifs inherents a l'architecture de la plateforme.

2. Informations generales de l'application

Champ	Valeur
Nom de l'application	YouTube
Package	com.google.android.youtube
Version	21.14.484 (code : 1561065532)
SDK Min / Cible	32 / 36

Champ	Valeur
Taille du fichier	54.23 MB
MD5	1a6e5de66543a557cc58a29d91ea0d55
SHA-256	6f59e54bfd7458de65ebf2ed984511a5d24e7e49bcf0d3dbc548d61991d43f71
Date d'analyse	26 avril 2026 — 12h43
Score de securite	52/100 — RISQUE MOYEN (Grade B)
Trackers detectes	1/432 (Google Firebase Analytics)

3. Synthese des resultats

Categorie	HIGH	MEDIUM	INFO	SECURE
Analyse du code	1	9	2	3
Manifeste Android	0	35	0	0
Securite reseau	1	1	0	1
Certificat	1	0	1	0
TOTAL	3	47	2	4

4. Vulnerabilites critiques et significatives

VULN-01 | [HIGH] Chiffrement CBC avec padding PKCS5/PKCS7 — Padding Oracle Attack

Severite	HIGH
Reference	CWE-649 OWASP MASVS: MSTG-CRYPTO-3 OWASP Top10 M5
Fichiers concernes	defpackage/hat.java, defpackage/te.java, defpackage/vid.java
Description	L'application utilise le mode de chiffrement AES-CBC avec le padding PKCS5/PKCS7. Cette combinaison est connue pour etre vulnérable aux attaques de type 'Padding Oracle', permettant a un attaquant de dechiffrer ou falsifier des donnees chiffrees sans connaitre la cle secrete.
Impact	Compromission de la confidentialite et de l'integrite des donnees chiffrees.
Recommandation	Migrer vers AES-GCM (mode AEAD) qui garantit a la fois confidentialite et integrite sans etre vulnérable au padding oracle.

VULN-02 | [HIGH] Trafic reseau en clair autorise pour tous les domaines

Severite	HIGH
Reference	OWASP MASVS: MSTG-NETWORK-2 CWE-319
Description	La configuration de securite reseau (network_security_config.xml) autorise le trafic HTTP en clair pour l'ensemble des domaines. Seuls youtube.com et googleapis.com beneficient d'une protection explicite. Un attaquant en position MITM pourrait intercepter des communications sensibles.
Faux positif ?	Partiellement. Pour une application de streaming video grand public, certains contenus CDN peuvent legitiment transiter en HTTP. Cependant, toute communication authentifiee devrait imperativement utiliser HTTPS.
Recommandation	Restreindre cleartextTrafficPermitted a false par default et n'autoriser d'exceptions qu'apres justification explicite pour chaque domaine.

VULN-03 | [HIGH] Signature avec algorithme MD5 — Vulnerabilite aux collisions de hash

Severite	HIGH
Reference	CWE-327 OWASP MASVS: MSTG-CRYPTO-4 OWASP Top10 M5
Detail technique	Le certificat de signature utilise MD5 comme algorithme de hachage (hash: d046fc5d1fc3cd0e57c5444097cd5449). MD5 est considere comme cryptographiquement casse depuis 2004 et vulnerable aux attaques de collision.
Contexte	Il s'agit du certificat historique de Google (valide depuis 2008). Ce finding est probablement un faux positif fonctionnel car Android utilise principalement les signatures v2/v3/v4 pour la verification. Toutefois, le certificat X.509 sous-jacent utilise bien MD5.
Recommandation	Migrer vers SHA-256 pour les nouvelles signatures. S'assurer que les schemes de signature v3/v4 sont actives.

VULN-04 | [WARNING] Composants Android exportes non proteges — 35 occurrences

Severite	MEDIUM / WARNING
Composants	24 activites, 8 broadcast receivers, 2 services exportes sans permission de protection adequates
Description	De nombreux composants sont declares comme exported=true sans qu'une permission de protection (signature-level) ne soit requise. Toute application tierce installee sur l'appareil peut potentiellement interagir avec ces composants.
Faux positifs	La majorite des activites exportees (HomeActivity, UrlActivity, UploadActivity) sont volontairement accessibles pour permettre l'integration inter-applications (deep links, partage). Ces cas constituent des faux positifs attendus.
Recommandation	Auditer chaque composant exporte pour verifier que son exposition est intentionnelle. Ajouter des permissions de niveau 'signature' pour les composants sensibles.

VULN-05 | [WARNING] Cles API et secrets en clair dans le code obfusque

Severite	MEDIUM / WARNING
Reference	CWE-312 OWASP MASVS: MSTG-STORAGE-14 OWASP Top10 M9
Exemple detecte	google_api_key : AlzaSyCtkvNIR1HCEwzsqK6JuE6KqpyjusIRI30 firebase_database_url : https://com--android.firebaseio.com
Contexte	La cle API Google detectable est vraisemblablement restreinte aux services Google internes et protegee par des quotas et restrictions d'API. Cependant, son exposition permet une enumeration et des tentatives d'abus.
Recommandation	Stocker les cles sensibles via le Keystore Android ou les injecter au build via des variables d'environnement CI/CD. Appliquer des restrictions strictes par bundle ID et IP sur la Google Cloud Console.

5. Analyse des faux positifs

Plusieurs alertes generees par MobSF sont des faux positifs inherents a l'architecture d'une application Google de grande echelle :

Alerte	Evaluation	Justification
Composants exportes (UrlActivity, HomeActivity, UploadActivity...)	Faux positif probable	Exposition intentionnelle pour deep links et integration systeme Android.
Anti-VM checks (Build.FINGERPRINT, Build.MANUFACTURER...)	Faux positif	Pratique standard pour detecter les environnements d'emulation et proteger contre le reverse engineering.

Alerte	Evaluation	Justification
Permissions malware (CAMERA, RECORD_AUDIO, ACCESS_FINE_LOCATION)	Faux positif contextuel	Justifiees par les fonctionnalites de streaming live, upload video et recommandations locales.
Secrets hardcodes (about_key, captions_key, etc.)	Faux positif	Ce sont des cles de preferences SharedPreferences, pas des secrets cryptographiques.
allowBackup=true	Vrai positif mineur	Peut exposer des donnees de sauvegarde via ADB. A corriger pour les builds de production.

6. Recommandations priorisees

#	Priorite	Action recommandee	Reference
1	CRITIQUE	Remplacer AES-CBC/PKCS7 par AES-GCM dans tous les modules de chiffrement identifies (hat.java, te.java, vid.java).	MSTG-CRYPTO-3
2	HAUTE	Activer les schemas de signature v3 et v4 pour les APKs de production. Mettre a jour le certificat de signature vers SHA-256.	MSTG-CRYPTO-4
3	HAUTE	Restreindre cleartextTrafficPermitted=false globalement. Lister explicitement les domaines CDN autorises en HTTP si techniquement necessaire.	MSTG-NETWORK-2
4	MOYENNE	Stocker la cle google_api_key via le Keystore Android ou via injection CI/CD. Appliquer des restrictions d'usage strictes sur la Google Cloud Console.	MSTG-STORAGE-14
5	FAIBLE	Desactiver android:allowBackup=true en production ou implementer un agent de sauvegarde securise pour controler les donnees sauvegardees.	MSTG-STORAGE-8

7. Conclusion

L'application YouTube presente un profil de securite generalement attendu pour une application grand public de cette envergure. Le score de 52/100 (RISQUE MOYEN) est principalement impacte par des vulnerabilites cryptographiques historiques et la large surface d'exposition de ses composants Android, en partie justifiee par ses cas d'usage legitiment ouverts (deep links, partage systeme, integration Google).

Les points les plus preoccupants restent l'utilisation d'algorithmes cryptographiques obsoletes (MD5, CBC) et l'autorisation du trafic reseau en clair par default. Ces elements devraient faire l'objet d'une correction prioritaire dans les prochaines iterations de l'application.

Les mecanismes de defense en profondeur identifies (SSL pinning, detection root/tapjacking, anti-debug, firebase analytics) temoignent d'une maturite securite reelle de l'equipe de developpement Google, qui doit neanmoins etre mise a jour sur les points cryptographiques identifies.

Hidaya Benchelha

Analyste Securite Mobile

Marrakech, 26 avril 2026